MEDCORE

HOSPITAL MANAGEMENT SYSTEM

Full System & Build Documentation

Modules: Patient Records · Appointments · Billing · Pharmacy · Laboratory · Staff · Reports

Frontend: React (Vite) | Backend: FastAPI (Uvicorn) | Database: PostgreSQL
Auth: JWT (Argon2 password hashing) | Session storage: browser session only
Email: Gmail SMTP, sent from the hospital's own mailbox — no third-party email provider

Prepared for: MEDCORE HMS Development Team

Document Version 4.6 — Final Build

Status: Complete — Single-language build, two-theme system, full role-based access control, hospital-mailbox email delivery

Table of Contents

1. Project Overview 5
- 1.1 Introduction 5
- 1.2 Objectives 5
- 1.3 Tech Stack 5
- 1.4 User Roles & Permissions 6
- 1.5 Theming System 8
- 1.6 Local Network Deployment & Email Delivery 8

2. Frontend Documentation (React) 10
- 2.1 Global Layout Components 10
- 2.2 Authentication Pages 11
- 2.3 Dashboard 11
- 2.4 Patient Records 12
- 2.5 Appointments 13
- 2.6 Billing 14
- 2.6a Refunds 15
- 2.7 Pharmacy 16
- 2.8 Laboratory 18
- 2.9 Staff Management 19
- 2.10 Reports 20
- 2.11 Settings 20
- 2.12 My Profile 21
- 2.13 Notifications 21
- 2.14 Error Page 22

3. Backend Documentation (FastAPI + Uvicorn) 23
- 3.1 Architecture Overview 23
- 3.2 Database Schema 23
- 3.3 API Endpoints 29

4. Known Limitations 39
- 4.1 Scope of This Documentation 39
- 4.2 Not Included in This Build 39
- 4.3 How the System Is Designed to Run 39
- 4.4 Changes and Additional Features 40

Full Feature Index

Every feature and interface element of the completed application, listed here for quick reference. Each item is expanded in full inside the Frontend and Backend sections that follow.

- Theme Toggle — switches between Clinical Light and Night Shift (Dark) themes app-wide, no reload
- Navbar — page title, role-limited global search, theme toggle, notification bell with live unread count, per-role quick-add button, role label + profile avatar
- Sidebar navigation — Dashboard, Patients, Appointments, Billing, Pharmacy, Laboratory, Staff Management, Reports, Settings, with Refunds also shown to Admin and Accountant, and with the logged-in user's role shown under the brand mark
- Footer — hospital name & copyright, app version, support/contact link
- Authentication — Login, Forgot Password, Reset Password, Set Password (first-time staff activation); session ends when the browser window closes; a deactivated account is refused at login and signed out on its next action
- Dashboard — key stat cards, today's appointment widget, revenue chart, recent patients table, quick actions
- Patient Records — patient list/search with each patient's last visit, add/edit patient (Admin and Receptionist), patient profile with Overview, Appointments, Billing, Account Details, Lab Results and Prescriptions tabs — each tab shown only to the roles allowed to see it and enforced on the backend, with refund bank details kept by the Accountant (Admin view-only)
- Appointments — hand-built month calendar and list views (date and time shown, searchable by patient name or ID, most recently changed first), book appointment (Admin and Receptionist; never in the past, and only with an active doctor) that auto-generates a fixed-fee invoice which must be paid in full before the assigned doctor can confirm, edit while pending, an enforced status workflow (cancelling needs a reason; Admin, Receptionist or the assigned doctor can cancel, mark no-show and reschedule; only the assigned doctor confirms or completes), rescheduling a missed appointment onto the same invoice, a booking note, the doctor's result (a diagnosis and a consultation note recorded when the appointment is completed), and patient emails on confirmation, reschedule and cancellation plus two reminders
- Billing — invoice list with search (patient name, patient ID or invoice number) and status filters, create/edit invoice with line items (only while unpaid), record payments, PDF receipts; the Accountant creates and edits invoices, records payments, cancels unpaid or partly paid invoices and processes refunds; Admin has view-only access to invoices, payments and receipts; no other role has billing access
- Refunds — audit page of every refund processed (Appointment, Lab Order, Prescription or Manual Invoice), with weekly, monthly and yearly ranges; Admin and Accountant can view it, only the Accountant can export it to Excel, and refunds themselves are issued only by the Accountant from Billing — for an appointment's invoice, only after the appointment has been cancelled
- Pharmacy — drug inventory in which every drug is described by its kind, strength, pack size and manufacturer (adding new drugs and stock is Pharmacist-only), stock kept in batches with their own expiry dates and used earliest-expiring first, expiry and low-stock alerts that generate real notifications, discontinuing a drug instead of deleting it, and write-off of expired stock with a record of who did it
- Prescriptions — the doctor writes the dose, how often and for how long, and the system works out the quantity and the price; the invoice is created when the prescription is saved; a saved prescription cannot be edited, only cancelled (by its doctor or an Admin) until it is dispensed, which tells Nurses, Pharmacists and the Accountant; the Pharmacist can open and dispense it only once the invoice is paid in full, confirms the drugs against it, and is recorded as the person who dispensed it
- Laboratory — test catalog (add/edit restricted to Lab Technician only), lab order list (the ordering doctor must be an active doctor), a payment gate that links every lab order to an auto-generated invoice, result entry with an optional PDF report, doctor notification and patient email on completion; result text and the PDF are visible to clinical roles only (a Receptionist sees status only)
- Staff Management — staff list with Active and Deactivated tabs and name search, add/edit staff with roles, and Admin-only deactivate and reactivate with an optional reason (nothing is deleted; a deactivated account is signed out, refused at login and hidden from the doctor and staff pickers); first-time passwords are set via an emailed activation link

- Reports — revenue, patients, appointments, pharmacy stock, lab utilization over weekly, monthly or yearly ranges; Admin sees all five and can export one report or every report at once to PDF/Excel; Accountant sees and exports the Revenue report only
- Settings — open to every role: hospital profile (view-only except for Admin), user preferences (Low Stock Alerts and Expiry Alerts, for Admin and Pharmacist), and, for Admin only, the roles & permissions matrix, fixed appointment fees and full data backup (database dump plus every uploaded document)
- Notifications — real, event-driven in-app notifications for low stock, drug batches nearing expiry, new and cancelled prescriptions, new lab orders, and completed lab results; live unread badge in the Navbar
- Patient Emails — sent from the hospital's own Gmail mailbox when a doctor confirms, reschedules or cancels an appointment, two reminders before every confirmed appointment (about a day before and about two hours before), when a lab result is marked completed, when an invoice is paid in full (with the PDF receipt attached), and when an invoice is cancelled or refunded
- My Profile — edit own info, change password

1. Project Overview

1.1 Introduction

The MEDCORE Hospital Management System (HMS) is a full-stack web application built to digitize the day-to-day operations of a hospital or clinic. It covers patient record keeping, appointment scheduling, billing, pharmacy stock and dispensing, and laboratory test management, all accessible through a single role-based dashboard.

This document describes the completed, as-built system: a single-language (English), two-theme, fully role-gated hospital management system with real business logic behind every workflow described below.

1.2 Objectives

- Replace paper-based patient records with a searchable digital system
- Give front-desk staff a fast way to register patients and book appointments
- Track billing, payments and outstanding balances per patient
- Prevent pharmacy stockouts and expired stock through low-stock and expiry alerts that generate real, targeted notifications
- Give lab technicians a structured, payment-verified workflow from order to result
- Give management real-time reports on revenue, patient flow, and stock
- Enforce strict, server-verified role-based access control on every write action, not just hide buttons in the interface

1.3 Tech Stack

Field	Type	Notes
Frontend	React (Vite)	SPA, component-based UI, calls the backend via REST through a single shared axios client
Backend	FastAPI (Python, Uvicorn server)	REST API, async request handling (SQLAlchemy async + asyncpg), auto-generated OpenAPI docs at /docs
Database	PostgreSQL	Relational schema — see Section 3.2
Auth	JWT (access + refresh tokens)	Issued by POST /api/auth/login, verified per request. Passwords hashed with Argon2 (via pwdlib), not bcrypt
Session storage	Browser sessionStorage	Tokens are cleared the moment the browser window or tab is closed — every role must log in again on next open; no persistent "remember me"
Styling	Tailwind CSS (utility classes generated from a small design-token set)	Consistent design system across every page, all colors read from CSS custom properties
PDF generation	reportlab	Used for invoice receipts and PDF report exports
Spreadsheet export	openpyxl	Used for Excel report exports and the refunds export
Email delivery	Gmail SMTP (Python's built-in smtplib — no third-party email API)	Sent directly from the hospital's own Gmail mailbox using an App Password. Every email attempt is also logged to the backend console as a permanent fallback, and is sent as a background task so a slow or unreachable mail server never blocks the user's action — see Section 1.6

Field	Type	Notes
Scheduler	APScheduler (runs inside the backend)	Checks every 5 minutes for confirmed appointments that are due a reminder email, and every 6 hours for drug batches nearing expiry; starts and stops with the server, so nothing extra has to be run
Hospital time zone	HOSPITAL_TIMEZONE setting in .env (default Africa/Lagos)	Appointment times are stored in UTC. A time typed into the booking form is read in this zone, and every appointment time shown in an email or the booking notification is converted back to it, so the computer running the backend can be set to any time zone
Migrations	Alembic	Schema changes are applied through versioned Alembic revisions
Rate limiting	slowapi (counts in memory or Redis)	Login and forgot-password (5 per minute) and the Navbar search (60 per minute) are rate-limited per client address. Counts are kept in the server's memory by default (REDIS_URL=memory://), or in Redis if REDIS_URL points at a Redis server, which runs alongside the backend

1.4 User Roles & Permissions

The system uses strict role-based access control (RBAC), enforced on the backend for every write action — not just hidden or shown in the interface. The table below summarizes each role's access; specific restrictions worth calling out are listed underneath.

Role	Access Summary
Admin	Full read access across the system and most administrative actions (staff, settings, reports). Cannot add or edit lab tests, and cannot add new drugs to inventory — those two actions are deliberately reserved for the specialist roles below, even for Admin. Billing is view-only for Admin: it can open invoices, payment history and receipts, and view the Refunds audit page (Section 2.6a), but cannot create, edit, cancel, pay or refund an invoice — those actions belong to the Accountant alone. Reports: all five report types, exportable one at a time or all at once. Sees every tab on a patient's profile, including the Account Details tab (refund bank details), which is view-only for Admin. Can book, cancel, mark no-show and reschedule appointments, but cannot confirm or complete one. Creates, edits, deactivates and reactivates staff accounts (Section 2.9). Edits a drug's details and discontinues or reactivates a drug, can open any prescription, and can cancel one that has not been dispensed (Section 2.7)
Doctor	Views patients and appointments, writes prescriptions (and can cancel their own until they are dispensed), orders lab tests. May confirm and complete an appointment only when they are the specific doctor assigned to that appointment; completing it records the appointment's result (a diagnosis and a consultation note). Reads a patient's appointments (with their results), prescriptions and lab results (including the PDF). Can also cancel, mark no-show and reschedule their own appointments with a reason; confirming requires the appointment's invoice to be paid in full
Nurse	Views patient records and appointments; can assist with lab order creation. Reads a patient's appointments (with their results), prescriptions and lab results (including the PDF). Is told when a prescription is cancelled
Receptionist	Registers patients and books appointments. Has no access to Billing, including simply viewing an invoice. On a patient's profile sees the Overview, Appointments and Lab Results tabs; lab results are status only — the result text, notes and PDF are withheld. Does not see appointment results or prescriptions. Can also cancel, mark no-show and reschedule appointments (cancelling needs a reason)

Role	Access Summary
Pharmacist	The only role permitted to add a new drug to inventory, add stock and write off expired stock. Also edits drug details and discontinues or reactivates a drug (alongside Admin), and dispenses prescriptions — only after the prescription's invoice is paid in full and the Pharmacist has confirmed the drugs against it; a pending prescription cannot be opened until it is paid. Is recorded as the person who dispensed it. Reads a patient's appointments (with their results), prescriptions and lab results to check for contraindications before dispensing; the lab PDF can be viewed but the Pharmacist has no Download button
Lab Technician	The only role permitted to add or edit a lab test in the test catalog (price, turnaround time, category). Confirms lab orders once payment clears, submits results, and completes orders. Reads a patient's lab results
Accountant	Owns billing: creates and edits invoices, records payments, cancels an unpaid or partly paid invoice, and processes refunds. Can view the Refunds audit page and export it to Excel. Reports access is limited to the Revenue report (view and export). Keeps each patient's refund bank details on the Account Details tab; on a patient's profile sees only the Overview, Billing and Account Details tabs, and a patient's blood group and allergies are withheld. Cannot place lab orders. Recording the full payment on an appointment's invoice is what allows the assigned doctor to confirm it

Enforcement note: every restriction above is checked on the backend (a rejected request returns HTTP 403), and mirrored on the frontend so a user is never shown a control they are not permitted to use. The frontend check exists purely for a clean user experience — the backend check is what actually protects the data.

Patient record access

Each kind of patient data has its own fixed role list, enforced on the backend (a rejected request returns HTTP 403, or the field is returned empty where stated). The tabs on a patient's profile are shown only to the roles that may read them.

Data	Who can read it
Patient list and profile overview	All staff (blood group and allergies are withheld from the Accountant)
Appointments tab	Admin, Doctor, Nurse, Receptionist, Pharmacist
Appointment result (diagnosis and consultation note)	Admin, Doctor, Nurse, Pharmacist. Every other role receives it empty
Prescriptions (profile tab, Pharmacy list and detail)	Admin, Doctor, Nurse, Pharmacist. A Pharmacist cannot open a pending prescription until its invoice is paid in full, and a Doctor sees only their own prescriptions in the Pharmacy list
Billing tab (invoices)	Admin, Accountant
Account Details tab (refund bank details)	View: Admin, Accountant. Edit: Accountant only
Lab results — test, date and status	Admin, Doctor, Nurse, Receptionist, Pharmacist, Lab Technician
Lab results — result text, notes and PDF (View)	Admin, Doctor, Nurse, Pharmacist, Lab Technician
Lab results — PDF Download button	Admin, Doctor, Nurse, Lab Technician (the Pharmacist views only)
Appointment booking note and cancellation reason	Admin, Doctor, Nurse, Receptionist; every other role receives them empty

The Download split is a convenience, not a barrier: a PDF opened in the browser can still be saved from the browser's own viewer. The control that actually protects a result is the backend, which will not serve the file to a role outside the list. Refund bank details are not part of the patient record — they are not collected at registration and are read and written only through their own endpoints (Section 3.3).

1.5 Theming System

The UI supports two built-in themes, switched at runtime with no page reload. All color values are CSS custom properties, so every component reads color through a variable rather than a hard-coded hex value.

Theme	Type	Notes
light (default)	Clinical Light	Daytime use — pale blue-white surface, deep teal accent
dark	Night Shift	Low-light wards / night rounds — near-black surface, matching teal accent tuned for legibility on a dark background

How it works:

- index.css defines the token set (--hms-bg, --hms-surface, --hms-surface-2, --hms-text, --hms-text-dim, --hms-accent, --hms-accent-on) twice, once per theme, scoped under :root[data-theme="..."]
- ThemeToggle.jsx sets the data-theme attribute on the <html> element; every variable recalculates instantly and every component re-renders with the new palette — no per-component logic needed
- Components consume the tokens as Tailwind utility classes generated from the @theme block — e.g. bg-hms-surface, text-hms-accent, text-hms-text-dim — rather than arbitrary bg-[var(--hms-...)] values
- Status colors (--hms-success, --hms-warning, --hms-danger, --hms-info) are defined once, outside the theme blocks, and stay constant across both themes — a "Cancelled" badge must always read as danger-red regardless of which theme is active

1.6 Local Network Deployment & Email Delivery

The system is designed to run entirely on a hospital's own local server, with every connected computer in the building reaching it over the local network (LAN) rather than the public internet. Email — activation links, password resets, appointment confirmations, reminders, reschedules and cancellations, lab-result notices, paid-invoice receipts, and refund and invoice-cancellation notices — is sent directly from the hospital's own Gmail mailbox using Python's built-in smtplib, with no third-party email API or paid service involved.

Two separate things happen when the system sends an email

- Sending the email itself travels over the internet, via Gmail's mail servers — this works from anywhere the server machine has an outbound internet connection, the same as any normal email client
- Any link inside that email (e.g. a "Set your password" link) is just text pointing at a URL. That URL is only reachable by devices on the same local network as the server, and only if it points at an address the whole network can resolve — not the word "localhost", which always means "whichever device opened this link", not the server itself

> **Correct setup:** CORS_ORIGINS in .env must be set to the server machine's real LAN IP address (e.g. http://192.168.1.50:5173), not localhost — every emailed link is built from this value. The server machine should be given a fixed IP via a router DHCP reservation, so links never break after a restart, and the frontend must be started with a flag that binds it to the network (not just the machine itself) for other computers to reach it at all. The frontend must also be told where the API is: set VITE_API_BASE_URL=http://<server LAN IP>:8000/api in the frontend's .env on the server machine and restart it, otherwise every other computer would call its own localhost and could not reach the backend.

Why SMTP port 465, not the more common 587

Many ISPs and routers block outbound port 587 (the standard STARTTLS mail port) as an anti-spam measure, while port 465 (implicit SSL) gets through. The email service is configured for port 465 (SMTP_SSL). On a different network, both ports are worth testing before assuming either one is blocked.

Every email send happens in the background

Confirming an appointment, completing a lab result, recording a payment, or creating a staff account all return an immediate response to the user interface — the actual email attempt runs afterward, as a background task, and never blocks or delays the action itself. If the mail server is temporarily unreachable, the underlying action (the appointment

is still confirmed, the payment is still recorded) always succeeds regardless; only the email notification is affected, and every attempt — successful or not — is logged to the backend console as a permanent fallback record.

Appointment times and the hospital time zone

Appointment times are stored in UTC. The hospital's time zone is set once with the HOSPITAL_TIMEZONE setting in .env (default Africa/Lagos, any standard time zone name works). A date and time typed into the booking form is read in that zone, and every appointment time shown in a patient email or the booking notification is converted back to it. The computer running the backend can therefore be set to any time zone. The screens themselves display times in the time zone of the browser viewing them.

2. Frontend Documentation (React)

This section documents every screen in the completed React application, describing its purpose, UI elements, and the primary user actions it supports.

Folder structure (Client_Side/medcore-hms/src)

- components/layout/ — Navbar.jsx, NavbarSearch.jsx, SideBar.jsx, Footer.jsx, ThemeToggle.jsx (shared shell, used on every authenticated page)
- components/shared/ — PatientPicker.jsx, StaffPicker.jsx (search-and-select inputs reused across modules)
- components/ui/ — Avatar, Badge, Button, Card, EmptyState, Input, Modal, Table, Tabs, ToastContainer (base design-system primitives)
- modules/<name>/ — one folder per module (dashboard, patients, appointments, billing, pharmacy, laboratory, staff, reports, settings, notifications, refunds), each with a <Name>View.jsx entry point and its own components/ folder
- hooks/ — useAuth, useFetch, usePagination, useInfiniteList (list that loads more as the user scrolls — used by the Billing list), useDebounce, useToast, useUnreadNotificationsCount
- services/ — one file per API resource (authService, patientService, appointmentService, billingService, pharmacyService, laboratoryService, staffService, reportService, notificationService, settingsService, refundService), all built on a single shared apiClient.js
- index.css — theme tokens for both themes, see Section 1.5
- App.jsx / main.jsx — application entry point, providers (Theme, Auth, Permissions), and routing

2.1 Global Layout Components

File location: src/components/layout/ — Navbar.jsx, NavbarSearch.jsx, SideBar.jsx, Footer.jsx, ThemeToggle.jsx. These five are shared across every authenticated page in the app.

Navbar.jsx (persists on every authenticated page)

- Left: current page title
- Center: global search bar (NavbarSearch.jsx) — from 2 characters it lists matching patients, appointments and invoices in a dropdown, 5 per group, and clicking a result opens the record. Each role sees only the groups it may use: Admin all three; Doctor, Nurse and Receptionist patients and appointments; Accountant patients and invoices; Pharmacist and Lab Technician patients. Only names, codes, statuses and times are shown, never notes, reasons or amounts
- Right: ThemeToggle.jsx — a two-way switch between Light and Dark, sets data-theme on <html>
- Right: Notification bell — shows a live unread-count badge (polled every 30 seconds), links through to the full Notifications page
- Right: Quick-add "+ New" button — opens a menu that depends on the role: Admin: New Patient, New Appointment, New Staff Member; Doctor: New Prescription, New Lab Order; Nurse: New Lab Order; Receptionist: New Patient, New Appointment, New Lab Order; Pharmacist: New Drug; Lab Technician: New Lab Order, New Lab Test; Accountant: New Invoice. An item appears only if the role has that module open, and the button is hidden when a role has nothing to create
- Right: Profile avatar — links to My Profile, Settings, Logout

SideBar.jsx (left-hand navigation)

Built from a single NAV_ITEMS array (one entry per module: id, icon, path), so adding a module to the sidebar is a one-line change. The brand mark at the top shows the logged-in user's role directly underneath the MEDCORE wordmark (e.g. "Admin", "Nurse", "Lab Technician"), so the currently active account is always visible at a glance.

- dashboard, patients, appointments, billing, pharmacy, laboratory, staff, reports, settings — each with its own icon. An Admin or Accountant also sees a Refunds item, since the Refunds page is a view-only audit page for those two roles (Section 2.6a)
- Items are filtered per the logged-in user's configured module permissions before rendering
- Active route styling: bg-hms-accent text-hms-accent-on with a soft accent-colored shadow. Inactive items: text-hms-text-dim, hover:bg-hms-surface-2 hover:text-hms-text

Footer.jsx (persists on every page)

- Left: © MEDCORE Hospital Management System, current year
- Center: app version number (v1.0.0)
- Right: Support / Contact link

2.2 Authentication Pages

Login — route: /login

Purpose: authenticate staff before entering the app.

- Hospital logo / branding
- Email input
- Password input
- "Forgot password?" link
- Login button — calls POST /api/auth/login, stores the JWT in sessionStorage, redirects to Dashboard
- Inline message area for invalid credentials and for an unverified or deactivated account, and for a rate-limited login ("Too many attempts. Please wait a minute and try again."); also shows the one-time notice left when a signed-in user was deactivated and signed out

Forgot / Reset / Set Password

- Forgot Password (/forgot-password) — email input, "Send Reset Link" button (POST /api/auth/forgot-password)
- Reset Password (/reset-password/{token}) — new password + confirm password fields (POST /api/auth/reset-password)
- Set Password (/set-password/{token}) — shown the first time a newly created staff account is activated; a temporary password is never generated or emailed — this link is the only way in. The activation link is sent for real, from the hospital's own Gmail mailbox; every send attempt is also printed to the backend console as a permanent fallback record, whether or not the email itself succeeds
- A deactivated account is refused at login, at token refresh, and by the forgot-password, reset-password and set-password flows (no reset link is sent to it). A signed-in user who is deactivated is signed out on their next action, with a notice on the login screen

2.3 Dashboard

File: src/modules/dashboard/DashboardView.jsx. Purpose: give each staff member an at-a-glance view of the hospital activity their role may see. Each role gets only its own cards and widgets, and the backend leaves out anything the role may not see. Built from five components:

- StatMetricCard.jsx — one card per key number: Total Patients, Today's Appointments, Pending Bills, Low-Stock Drugs, Pending Lab Results. Total Patients is shown to every role; Today's Appointments to Admin, Doctor, Nurse and Receptionist (a Doctor sees only their own, titled "My Appointments Today", and cancelled visits are not counted); Pending Bills to Admin and Accountant; Low-Stock Drugs to Admin and Pharmacist (usable stock only; discontinued drugs are left out); Pending Lab Results to Admin and Lab Technician
- LiveAppointments.jsx — today's appointment schedule widget (patient, doctor, time, status badge) for Admin, Doctor, Nurse and Receptionist; "today" is the hospital's own day, and a Doctor sees only their own appointments

- RevenueChartCard.jsx — revenue chart with a weekly/monthly toggle, pulled from GET /api/reports/revenue; shown to Admin and Accountant only
- RecentPatientTable.jsx — last few patient registrations, name / ID / demographics / time-since-registered; shown to Admin, Doctor, Nurse and Receptionist
- OperationalQuickActions.jsx — quick action buttons: the same per-role list as the Navbar "+ New" menu (Section 2.1), hidden when a role has nothing to create

2.4 Patient Records

Patients List — route: /patients

- PatientSearchFilter.jsx — search bar (name or patient ID) plus a gender filter
- PatientDirectoryTable.jsx — table columns: Patient (avatar + name + ID), Age, Gender, Last Visit (the latest of the patient's registration, a completed appointment, a payment recorded on any of their invoices or a dispensed prescription, shown as a date)
- "Add New Patient" button — shown only to Admin and Receptionist (the roles that may register a patient); pagination

Add / Edit Patient — route: /patients/new, /patients/{id}/edit

- Personal info: full name, date of birth, gender, phone, email, address
- Emergency contact: name, relationship, phone
- Medical info: blood group, known allergies
- Insurance info: provider, policy number
- Save button — POST /api/patients or PUT /api/patients/{id}
- Admin and Receptionist only — any other role that opens /patients/new or /patients/{id}/edit directly sees a "no access" message. Banking details are not part of this form: they are kept by the Accountant on the patient's Account Details tab

Patient Profile — component: PatientProfileTabs.jsx, route: /patients/{id}

Tabbed view of a single patient's full record, opened from the directory table. Each tab lazily fetches its own data, only firing once that tab is actually selected. A role is only shown the tabs it may read (Section 1.4); the backend independently refuses everyone else. The Edit button in the header is shown to Admin and Receptionist only, and the header shows the patient's age, worked out from the date of birth, and the date the patient was registered:

- Overview tab — contact information, insurance and emergency contact (every role that can open the profile)
- Appointments tab — every appointment for this patient (Admin, Doctor, Nurse, Receptionist, Pharmacist). For Admin, Doctor, Nurse and Pharmacist each row opens the doctor's result for that appointment, or "No result for this appointment yet."; the Receptionist's rows are plain status information
- Billing tab — invoices and payment status for this patient (visible to Admin and Accountant only, matching the module-wide billing restriction)
- Account Details tab — the patient's refund bank name and account number, kept for refunds when the patient is not at the hospital (Admin: view only; Accountant: view and edit). It is a reference only — the destination of a refund is always confirmed with the patient. These details are never returned by GET /api/patients/{id}
- Lab Results tab — completed and pending lab orders, in three tiers. Admin, Doctor, Nurse, Receptionist, Pharmacist and Lab Technician see the list (test, date, status). Everyone except the Receptionist can open a result to read the Result Data and Notes and to View the PDF. The Download button is shown to Admin, Doctor, Nurse and Lab Technician only (the Pharmacist views only). A Receptionist therefore sees status only — the result text, notes and file link are removed from the response by the backend. The Accountant does not see the tab, and the backend rejects them
- Prescriptions tab — the patient's prescriptions with their status (Pending, Dispensed or Cancelled) and, once dispensed, who dispensed them and when; each one opens to show its drugs, quantities and instructions (Admin, Doctor, Nurse, Pharmacist). Cancelling is done from Pharmacy > Prescriptions

2.5 Appointments

Appointments — route: /appointments

File: src/modules/appointments/AppointmentsView.jsx. Toggles between a List view and a hand-built month Calendar view — this is a purpose-built component with no external calendar dependency.

- AppointmentToolbar.jsx — Calendar/List view switch, status filter, a search box (patient name or patient ID; it waits until typing pauses, then queries the server) and the "Book Appointment" button, shown to Admin and Receptionist only. Changing the filter or the search returns the list to page 1
- AppointmentList.jsx — the appointment rows: patient (with the patient code beneath the name), doctor, appointment type, date and time, status badge. The list is ordered by when each appointment was last changed — booked, edited, confirmed, cancelled, marked no-show or rescheduled — so the most recent activity is at the top
- CalendarMonthView.jsx — month grid only (no week/day/agenda modes). Prev / Next / Today navigation. Fetches only the visible month's appointments via a dedicated from/to date-range query parameter on GET /api/appointments, rather than pulling a large flat batch. Days containing appointments show small colored status dots and are clickable, opening a modal that lists that day's appointments; clicking an appointment in the modal opens its detail page. Empty days are inert by design — this calendar is a viewing surface, not a quick-create shortcut. It follows the same status filter and patient search as the list
- Color-coded status badges: Pending, Confirmed, Completed, Cancelled, No-show — using the fixed --hms-warning / --hms-success / --hms-info / --hms-danger tokens so status meaning never shifts with the active theme

Book / Edit Appointment — route: /appointments/new, /appointments/{id}/edit

- Patient selector (searchable)
- Doctor selector — lists active doctors only
- Date & time picker — a date or time in the past cannot be booked (past days are greyed out in the picker, and the backend rejects it; the current time is accepted, and a few minutes' allowance covers walk-ins). When editing, the time is only checked if it is changed
- Appointment type (consultation, follow-up, emergency) and reason for visit
- Booking note field
- Save button — POST /api/appointments or PUT /api/appointments/{id}
- Editing is possible only while the appointment is Pending. Once it is confirmed, completed, cancelled or marked no-show its details are locked: the backend rejects the edit with HTTP 400 and the form shows a "can no longer be edited" message if opened directly. To change a confirmed appointment, cancel it and book a new one
- Changing the appointment type while editing updates the linked invoice to that type's fee, but only while nothing has been paid on it; once a payment is recorded the type field is locked, and a different type means cancelling the appointment, having the Accountant refund the payment, and booking again

> **Automatic billing and payment gate:** booking an appointment (POST /api/appointments) automatically generates a one-line invoice priced from the Admin-configured fee for that appointment's type (Consultation / Follow-up / Emergency — see Section 2.11). The assigned doctor cannot confirm the appointment until that invoice has been paid in full by the Accountant; every appointment type, including Emergency, is subject to the same rule. Until then the appointment page shows "Awaiting payment" in place of the Confirm button (the doctor and front desk see only the payment status, never amounts), and a premature confirmation attempt is rejected by the backend with HTTP 400 — exactly like the payment gate on lab orders (Section 2.8). The invoice also feeds Reports > Revenue.

Appointment Details — route: /appointments/{id}

Status is a strict one-way state machine, enforced on the backend as well as reflected in which buttons the interface shows:

- Pending → Confirmed (only the doctor assigned to this specific appointment, and only once its invoice is paid in full) or Cancelled (Admin, Receptionist, or the assigned Doctor — a reason is required)

- Confirmed → Completed (only the assigned doctor, not before the scheduled time, and with the appointment's result), No-show (Admin, Receptionist, or the assigned Doctor, not before the scheduled time) or Cancelled (Admin, Receptionist, or the assigned Doctor — a reason is required)
- No-show → Cancelled (once the patient confirms they no longer want the appointment) or Rescheduled, described below. Completed and Cancelled are terminal — no further status change is possible from either
- Cancelling — a written reason is required (it is shown on the appointment to Admin, Doctor, Nurse and Receptionist and is not included in the patient's email). Cancelling cancels the linked invoice and emails the patient; if the invoice had already been paid, the Accountant can then refund it from Billing (Section 2.6)
- Rescheduling a no-show — the "Reschedule" button (Admin, Receptionist or the assigned Doctor) asks only for a new date and time in the future, and creates a new Pending appointment for the same patient, doctor, type and reason, linked to the missed one. It reuses the same invoice, so nothing is billed twice, and the patient is emailed the new time. The no-show stays on record; its page links to the new appointment, and it cannot be changed again once rescheduled
- Confirmation prompts — Mark No-show and Cancel each ask for a second confirmation before they act, and Mark Completed opens the result form first and then asks for confirmation

A doctor viewing an appointment they are not assigned to sees a plain status message instead of action buttons (e.g. "Awaiting confirmation from Dr. X"); attempting the transition directly against the API from an unauthorized account is independently rejected by the backend with HTTP 403 or HTTP 400 for an invalid transition.

- Patient info snapshot and doctor assigned
- Payment — the status of the linked invoice (Awaiting payment / Partially paid / Paid / Invoice cancelled / Refunded), without any amounts
- Booking note — the remark the Receptionist enters when booking, shown read-only to Admin, Doctor, Nurse and Receptionist; every other role receives it empty. The cancellation reason follows the same rule
- Appointment Result section — shown on every appointment to Admin, Doctor and Nurse (the roles that can open the page; the Pharmacist reads it from the patient's Appointments tab): the diagnosis and consultation note with the time they were recorded, or "No result for this appointment yet." until the doctor completes the appointment. The server returns the result only to Admin, Doctor, Nurse and Pharmacist, so the Receptionist's page has no such section
- Result form — "Mark Completed" (the assigned doctor only, once the scheduled time has been reached) opens a form with two required text fields, Diagnosis (up to 2,000 characters) and Consultation note (up to 5,000). Continue opens a confirmation window that repeats what was typed; "Back to the form" keeps the text, and "Save and mark completed" saves the result and completes the appointment in one request (PATCH /api/appointments/{id}/status with the result). A saved result cannot be edited
- "Edit Appointment" shortcut — shown only while the appointment is Pending, and only to Admin, Receptionist or the assigned Doctor

2.6 Billing

> **Access note:** every endpoint in the billing module — including simply listing or viewing an invoice — is restricted to the Admin and Accountant roles. The Accountant owns every billing action: creating and editing invoices, recording payments, cancelling an unpaid or partly paid invoice, and processing refunds. Admin is view-only (invoice list and detail, payment history, receipts). Receptionist, doctor, nurse, pharmacist and lab technician have no access to billing data of any kind. The same rules are enforced on the backend (HTTP 403) and mirrored in the interface, which hides every control the logged-in role cannot use.

Invoices List — route: /billing

- Table: Invoice # , Patient (name, with the patient code beneath it so patients who share a name can be told apart), Date Issued, Amount, Status (Unpaid / Partial / Paid / Cancelled / Refunded)
- Filter by status (All, Unpaid, Partial, Paid, Cancelled, Refunded)
- Search box (Admin and Accountant) — matches patient name, patient ID or invoice number, and combines with the status filter. It waits until typing pauses, then queries the server. Invoices load 20 at a time inside a scrolling

area and the next batch loads as the user scrolls, with a "Showing X of Y" counter, so a search that matches hundreds of invoices never loads at once

- "Create Invoice" button — Accountant only

Create / Edit Invoice — route: /billing/new, /billing/{id}/edit (Accountant only; any other role sees a "no access" message)

- Patient selector
- Line items: description, quantity, and unit price — editable rows with an "Add Line Item" control
- Discount and tax fields; the total is always recalculated server-side on save, never trusted from the frontend's own display math
- Save button — POST /api/invoices or PUT /api/invoices/{id}
- Only an unpaid invoice can be edited — once a payment is recorded, or the invoice is cancelled or refunded, its lines and total are fixed (the form shows a message instead, and the backend rejects the edit with HTTP 400)

Invoice Detail / Payment — route: /billing/{id}

- Full invoice breakdown (line items, subtotal, discount, tax, total)
- "Record Payment" form: amount, method (cash, card, insurance, bank transfer), reference number — Accountant only, shown while the invoice is unpaid or partial
- Payment history table for this invoice
- "Download Receipt" — generates and downloads a real PDF receipt via the backend (reportlab), openable and printable through the browser's normal print dialog
- "Refund" — Accountant only — available once an invoice has at least one payment recorded and is not already refunded; the Accountant enters the amount to refund, up to the amount paid. Sends the patient a refund-confirmation email and moves the invoice to a terminal Refunded state. An invoice that belongs to an appointment can be refunded only after that appointment has been cancelled: while it is pending, confirmed, marked no-show or completed, the page explains that the appointment must be cancelled first (a completed appointment cannot be refunded). An invoice that belongs to a prescription can be refunded only after the prescription has been cancelled, and never once it has been dispensed
- "Cancel Invoice" — Accountant only, offered only while the invoice is unpaid or partial. Moves the invoice to a terminal Cancelled state, excludes it from Reports > Revenue, and emails the patient that it is no longer due and that any payment already made will be refunded separately. A paid, already cancelled or already refunded invoice is rejected with a message that names its state; a paid invoice goes through Refund instead. If the invoice belongs to a pending prescription, cancelling it cancels the prescription too, so it can no longer be dispensed, and Nurses, Pharmacists and the prescribing doctor are notified

An invoice's status is recalculated automatically every time a payment is recorded: Unpaid until any payment exists, Partial once total payments are less than the invoice total, and Paid the moment total payments meet or exceed it — there is no separate manual "mark as paid" action. Cancel and Refund (both Accountant only) each move an invoice to a terminal state — cancelled or refunded respectively — and neither can be reversed or repeated once set. Admin can view the result but cannot trigger either action. Recording the full payment on an appointment's invoice is what allows the assigned doctor to confirm that appointment.

2.6a Refunds

Access note: this page and every endpoint behind it is restricted to Admin and Accountant, matching the backend's own restriction (Section 3.3). The list is view-only for both roles; only the Accountant sees the Export button. It is intentionally left out of the configurable Roles & Permissions matrix (Section 1.4), so it can never be granted to any other role.

Refunds — route: /refunds

- Table: Invoice #, Patient, Source (Appointment / Lab Order / Prescription / Manual Invoice, inferred from the invoice’s line items), Amount, Processed By, Refunded At

- Weekly / Monthly / Yearly range toggle (last 7, 30 or 365 days), matching the ?range query parameter on GET /api/refunds; the list is paginated and the Total Refunded card shows the server-side sum for the whole range, not just the visible page
- Export to Excel button (Accountant only) — calls GET /api/refunds/export
- Read-only: a refund is created by the Accountant from the Billing module's Invoice Detail page (Section 2.6), not from here — this page is purely an audit trail of refunds already processed

2.7 Pharmacy

Drug Inventory — route: /pharmacy

- Inventory and Prescriptions tabs at the top of the page switch between the two lists
- Table: Drug (name with its strength and form, such as "Septrin 500 mg tablet", with the manufacturer beneath it), Stock (usable units, with the cards or packs they make up), Unit Price (per unit), Next Expiry and Status — In Stock, Low Stock, Out of Stock, Expired or Discontinued
- Stock counts only usable units: a batch stops counting the day it expires, and units still sitting in expired batches are shown as expired
- Low-stock rows highlighted; "Low Stock Only" filter toggle; "Discontinued Only" filter for Admin and Pharmacist — a discontinued drug appears only there
- "Add Drug" button — visible only to the Pharmacist role. Every other role, including Admin, can view the full inventory but cannot add a new drug

Add / Edit Drug — route: /pharmacy/new, /pharmacy/{id}/edit

- "What kind of item is this?" comes first: tablet, capsule, suppository, syrup, oral drops, eye drops, ear drops, nasal drops, injection, IV drip, syringe, cream or other. The form then shows only the fields that kind of item needs
- Name (without the strength), category and manufacturer — all required
- Strength and unit — required for tablets, capsules, suppositories, syrups, oral drops and injections. For the other kinds the Pharmacist enters a strength or ticks "No strength" (for example saline); syringes have none. The units offered depend on the kind of item, and the server rejects a unit that does not suit it:

Kind of item	Strength units offered
Tablet, capsule	mcg, mg, g, units (starts at mg)
Suppository	mcg, mg, g (starts at mg)
Syrup, oral drops	mcg, mg, g, units (starts at mg)
Eye, ear and nasal drops	%, mcg, mg, g, units (starts at %)
Injection	mcg, mg, g, units, % (starts at mg; a multi-dose vial cannot use %)
IV drip, cream	%, mcg, mg, g, units (starts at %)
Other	mcg, mg, g, units, % (starts at mg)
Syringe	None — size only

- Volumes — a syrup or oral drops asks for the volume the strength refers to ("Per", as in 125 mg per 5 mL) and the bottle size; the other liquids ask for their bottle or bag size. A percentage strength has no "Per" box, and a multi-dose vial cannot use a percentage. A line beneath the fields reads the entry back, for example "125 mg per 5 mL"
- "Measure volumes in" — mL or cL, on every item that has a volume. Switching converts what is already typed (100 mL becomes 10 cL) and relabels the boxes. The server always stores mL, every screen shows mL and an edited drug reopens in mL, so cL is only an entry convenience. Syringes stay in mL
- Routes — an injection lists the routes the product allows (IV, IM, subcutaneous), a suppository is rectal or vaginal and an IV drip is IV. "Multi-dose vial (e.g. insulin)" asks for the vial volume and the strength per mL

- Syringes — a size in mL chosen from a list; an insulin syringe (U-100 or U-40) is 0.3, 0.5 or 1 mL
- "Comes in" (card, strip, box, bottle, vial, ampoule, bag, tube or pack) and, for tablets, capsules, suppositories and syringes, how many pieces are in one pack. The price is per unit (one tablet, one bottle), with the price per pack shown beneath it
- New drug: stock received (in packs), the expiry date of that stock (after today) and the reorder level in packs; the page shows what the packs come to in units. Every field is required
- The name is checked against the catalogue while typing: the same name from another manufacturer, strength or form is only a note, while the same product (name, manufacturer, form and strength) is an error with a link to open it
- Save button — POST /api/drugs (Pharmacist only) or PUT /api/drugs/{id} (Admin + Pharmacist). Editing changes details and the reorder level only; stock moves through restocking, dispensing and write-offs. The kind of item and the pack size are locked while the drug has any units on hand
- Discontinue / Reactivate button in edit mode (Admin and Pharmacist, with an optional reason). Nothing is deleted: a discontinued drug cannot be prescribed or restocked and leaves the default inventory list, the low-stock counts and the alerts, while past prescriptions and invoices keep it. Discontinuing is refused while the drug has usable stock or a pending prescription includes it; any expired units still on the shelf are written off in the same step

Stock Batches — shown below the form when a drug is opened (Admin and Pharmacist)

- Each delivery is its own batch with its own expiry date. The panel lists every batch: expiry date, units received, units left and status (usable, expired or empty)
- Add stock — Pharmacist only: packs received and an expiry date after today (POST /api/drugs/{id}/restock). A discontinued drug cannot be restocked
- Write off — Pharmacist only: removes the units left in an expired batch and records who did it, when and why. A batch that has not expired cannot be written off
- First expiring, first out: dispensing always takes from the earliest-expiring batch, and expired stock is never prescribed or dispensed

Prescriptions — route: /pharmacy/prescriptions

- Table: Patient (the name opens the prescription), Doctor, Date (with the time, newest first), Items and Status (Pending / Dispensed / Cancelled; a pending prescription also shows Paid or Awaiting payment, never an amount). Searchable by patient name or patient ID, with an All / Pending / Dispensed / Cancelled filter. The list and each prescription's detail are available to Admin, Doctor, Nurse and Pharmacist only, and a Doctor sees only their own prescriptions here
- Prescription detail window — each drug with its quantity, the cards and loose pieces it makes up and its written instruction; who prescribed it and when; where the patient is (waiting at billing, paid and waiting at the pharmacy, or dispensed, and by whom); and, for a cancelled prescription, who cancelled it, when and why. A Pharmacist cannot open an unpaid pending prescription: that row shows "Opens once paid"
- "New Prescription" button and window (shown to Doctors only) — see Writing a Prescription below
- "Dispense" action per pending row — Pharmacist only, once the invoice is paid in full
- "Cancel" action on a pending prescription — the prescribing Doctor or an Admin, with a required reason of up to 300 characters that is kept on the prescription and never put in a notification. Cancelling voids the invoice and emails the patient that it is no longer due; if payment was already made, the Accountant refunds it. Nurses, Pharmacists and the Accountant are notified (Section 2.13). A dispensed prescription cannot be cancelled

Writing a Prescription — "New Prescription" window (Doctor only)

- Patient selector, then one row per drug. The doctor is always the logged-in account, never trusted from the request body, and a drug can be added only once. A discontinued drug, or one without enough usable stock, is refused
- Each row shows only the fields its drug needs:

Drug	The doctor enters	Quantity worked out as
Tablet, capsule, suppository	Dose in pieces (whole or quarters), how often, for how long	Dose × number of doses, rounded up
Syrup, oral drops	Dose in mL, how often, for how long	Total mL ÷ bottle size, rounded up
Injection	Dose in the product's own unit, route, how often, for how long	Single-dose: whole ampoules or vials for each dose. Multi-dose vial: total dose ÷ vial content, rounded up
IV drip	Bags per dose, how often, for how long	Bags per dose × number of doses
Syringe	Quantity, picked from the sizes in stock	As typed
Eye, ear and nasal drops, cream, other	Number of packs and written instructions	As typed

- Frequencies: once daily, twice daily, three times, four times, at night, in the morning, every 6, 8 or 12 hours, once weekly, once monthly, immediately once, and when necessary (with the number of doses to supply). Durations are in hours, days, weeks or months (30 days each), up to a year. Each line records whether it is taken home or given at the hospital; injections, drips and syringes default to the hospital
- The quantity, line prices and total shown as the doctor types come from the server (POST /api/prescriptions/preview, the same code that saves), never from arithmetic in the browser, and the server also builds the one-line instruction
- Saving first asks the doctor to confirm that a saved prescription cannot be edited, only cancelled. Saving creates one invoice with a line per drug (price per unit × quantity) and notifies every Admin and Pharmacist

Dispense — route: /pharmacy/prescriptions/{id}/dispense

- Prescription details: patient, prescribing doctor, date and, for each drug, the quantity, the cards and loose pieces it makes up, the instruction and the stock available
- Which batch to take from: for each drug the screen says how many units to take from which expiry batch, earliest first, and notes when a drug is in stock with more than one expiry date
- Stock availability check per item before confirming — all items are validated before any stock is deducted, avoiding a partial dispense. Nothing can be dispensed until the invoice is paid in full
- Confirm Dispense button (Pharmacist only; Admin can view the screen but has no button) — opens a window listing the patient, the prescribing doctor and what to hand over. "Dispense now" stays disabled until the Pharmacist ticks that they have checked the drugs against the prescription
- PATCH /api/prescriptions/{id}/dispense needs {"confirmed": true} (HTTP 400 without it), takes the stock from the earliest-expiring batches, records which batches were used and records the Pharmacist as the person who dispensed it. If a dispense pushes any drug's usable stock at or below its reorder level, a real low-stock notification is generated automatically
- "Dispensed by <name> on <date and time>" is shown on the dispense screen, in the prescription detail window and on the patient's Prescriptions tab; a prescription with no recorded dispenser shows only the date

2.8 Laboratory

> **Access note:** adding or editing a lab test in the catalog is restricted to the Lab Technician role only — not Admin, and not any other role — to keep pricing and naming consistent and avoid duplicate catalog entries.

Test Catalog — route: /laboratory/tests

- List of available lab tests: Name, Category, Price, Turnaround Time
- "Add Test" button — Lab Technician only

- Inline "Edit" action per row — Lab Technician only, allows updating a test's name, category, price, or turnaround time at any time

Lab Orders — route: /laboratory/orders

Any role that can see lab results — Admin, Doctor, Nurse, Receptionist, Pharmacist and Lab Technician — may create a lab order (a nurse or receptionist frequently places the order on a doctor's behalf, recording which doctor is actually ordering it). The Accountant cannot, and the backend rejects the request. Creating an order automatically generates a linked one-line invoice, priced from the test catalog. The ordering doctor must be an active Doctor: a deactivated doctor does not appear in the selector, and the backend rejects the order.

- Table: Patient, Test, Ordered By, Date, Status (Pending / In Progress / Completed)
- "New Lab Order" button — patient, test, and ordering doctor selectors
- Pending orders show either a "Confirm" button (if the linked invoice is fully paid) or an "Awaiting Payment" label (if it is not) — the lab technician sees this directly on the order, with no need for billing access of their own. Confirm is shown to the Lab Technician and Admin, the two roles the backend allows to change an order's status; no other role sees it
- In Progress orders show "Enter Result" to the Lab Technician only. Completed orders show "View Result" to Admin, Doctor, Nurse, Pharmacist and Lab Technician; the Receptionist sees the status only, with no result button

> **Payment gate:** a lab technician cannot move an order from Pending into In Progress until the linked invoice has been paid in full. This is enforced on the backend (a premature confirm attempt returns HTTP 400), not just hidden in the interface — and it means every completed lab test also has a corresponding real invoice feeding into Reports' revenue figures.

Lab Result Entry — route: /laboratory/orders/{id}/result

- Order details (patient, test, ordering doctor)
- Result Data and Notes fields
- Optional PDF report — the lab technician can attach a PDF to a result and edit or replace it afterward; editing a completed result re-sends the patient's result-ready email with the corrected content. The file is stored on the server's disk and downloaded only through a role-checked endpoint (GET /api/lab-orders/{id}/report) open to Admin, Doctor, Nurse, Pharmacist and Lab Technician, never through a public URL. A Receptionist can see that a result exists and its status, but the result text, notes and file are withheld
- "Mark Completed & Notify Doctor" button — updates the order status and fires a real notification to the specific ordering doctor plus every Admin account

2.9 Staff Management

- Active tab (default) — table of Name, Role, Department, Contact and Status, with an action column — route: /staff
- "Add Staff" button (Admin only)
- Search by name and role filter chips (All Roles, then one per role). Every role other than Admin sees active staff only
- "Deactivate" button on each active row (Admin only; the Admin's own row shows "You" instead) — opens a confirmation box with an optional reason of up to 300 characters. The account is not deleted: everything it was linked to stays on record
- A deactivation is refused when the account is the Admin's own, when it is the last active Admin, or when it is a Doctor with any pending or confirmed appointment. For a doctor the box lists the blocking appointments (patient, date and time, status — up to ten, with the total) so they can be cancelled first: an Admin or Receptionist cancels them with a reason, and each patient is emailed. The same guards stop the last active Admin, and a Doctor with open appointments, from being given another role
- Deactivated tab (Admin only) — Name, Role, Department, when the account was deactivated and why, and a "Reactivate" button that restores access with the same password

- A deactivated account is signed out on its next action, cannot log in, refresh a session or use a reset or activation link, receives no notifications, no longer appears in the doctor and staff pickers, and cannot be chosen as the doctor of an appointment or lab order

Add / Edit Staff — route: /staff/new, /staff/{id}/edit

- Name, role (Admin / Doctor / Nurse / Receptionist / Pharmacist / Lab Technician / Accountant), department, phone, email
- No temporary password is ever generated or stored — a brand-new staff account is created in an unusable state until the staff member follows their emailed activation link and sets their own password (every send is also logged to the backend console as a fallback, in case the mailbox is unreachable)

2.10 Reports — route: /reports

- Report type selector: Revenue, Patient Registrations, Appointments, Pharmacy Stock, Lab Utilization — Admin sees all five, Accountant sees Revenue only
- Weekly / Monthly / Yearly range toggle — Weekly is the last 7 days, Monthly the last 6 calendar months, Yearly the last 5 calendar years
- Chart + underlying summary cards, whose labels and formatting are driven by a per-report-type lookup rather than a fixed set of hardcoded cards
- Every summary figure covers the same period as the chart, except the total patient count (every patient registered so far), the low-stock count and inventory value (as of today), which describe the present position rather than a period. In the Pharmacy report the inventory value is the usable (unexpired) stock times each drug's price per unit, and the low-stock count leaves out discontinued drugs
- Outstanding (Revenue) is what is still owed on unpaid and partly paid invoices issued in the period: their totals minus the payments already received. The Patients report shows New (registered in the period) and Total (every patient registered so far). Avg. Turnaround (Lab) is the average number of hours from a lab order being placed to its result being completed, over the orders placed in the period that are completed; an order with no recorded completion time is left out
- Export dropdown (PDF or Excel) — "This report" for the open report; Admin also gets "All reports", one file with every report under its own header (one page per report in the PDF, one sheet per report in the Excel file). Accountant exports Revenue only

> **Revenue figures:** the Revenue report totals every invoice issued within the selected period, regardless of whether it has actually been paid yet. An unpaid invoice — including one auto-generated by a lab order awaiting payment — is already counted as revenue the moment it is created, not the moment it is collected. The exceptions are cancelled and refunded invoices: the moment an invoice is cancelled or a refund is processed (Section 2.6, Billing), that invoice is excluded from Reports > Revenue from then on, regardless of how much of it had previously been counted.

2.11 Settings — route: /settings

Settings is open to every role (from the sidebar and the profile menu in the Navbar). Each tab is shown only to the roles that can use it:

- Hospital Profile tab — name, address, contact details. Every role can view it; only Admin can edit it. The phone number entered here appears in appointment reminder emails
- User Preferences tab (Admin and Pharmacist only; hidden for every other role) — Low Stock Alerts and Expiry Alerts: a user who switches one off no longer receives those notifications (theme is set from the always-visible Navbar toggle, not duplicated here)
- Roles & Permissions tab (Admin only) — a checkbox matrix of which modules each role can access; changes apply the next time a staff member logs in. Settings itself is not part of the matrix — every role can open it. The built-in defaults give Patients to the Accountant, Pharmacist and Lab Technician, but a saved matrix is used exactly as saved, so a saved matrix that lacks it needs the Admin to tick Patients for those roles. Which tabs a role sees inside a patient's profile is fixed (Section 1.4) and is not part of this matrix

- Appointment Fees tab (Admin only) — sets the fixed Consultation / Follow-up / Emergency fees auto-charged when an appointment is booked; not shown at all to any non-admin role, matching the backend's own restriction on both reading and writing this setting
- Backup & Data tab — Admin only — download one .zip containing a full pg_dump of the database, every uploaded document, and a README with restore steps (there is no in-app restore; restoring is done manually with psql)

2.12 My Profile — route: /profile

- Edit own name, phone, department
- Change password form (current password, new password, confirm)

2.13 Notifications & Patient Emails — route: /notifications

Two separate channels exist for letting people know something happened — in-app notifications for staff, and email for patients. Neither is decorative; both are generated by specific backend actions.

In-app notifications (staff, shown via the Navbar bell)

- A drug's stock dropping to or below its reorder threshold — sent to every Admin and Pharmacist who has Low Stock Alerts switched on (Section 2.11)
- A drug batch nearing expiry — a background job that runs every 6 hours notifies every Admin and Pharmacist who has Expiry Alerts switched on (Section 2.11): at 90 days and again at 30 days before the expiry date, and once when the batch has expired. Each stage is sent once per batch
- A new prescription being created — sent to every Admin and Pharmacist
- A prescription being cancelled (by its doctor or an Admin, or because its invoice was cancelled in Billing) — Nurses and Pharmacists are told so the patient can be found if they are at billing or the pharmacy; the Accountant is told when the doctor or an Admin cancelled it, with a prompt to refund if payment was already made; the prescribing doctor is told when an Admin or Billing cancelled it. A notification never carries the cancellation reason, which can be clinical
- A new lab order being created — sent to every Admin and Lab Technician
- A lab result being marked completed — sent to the specific ordering doctor, plus every Admin
- A new invoice being created — sent to every Admin
- Only active accounts are notified: a deactivated account receives none of the notifications above
- Full list of notifications with type icon, message, and timestamp; "Mark as read" per item and "Mark all as read"
- The Navbar bell shows a live unread-count badge, refreshed automatically every 30 seconds

Patient emails (sent from the hospital's own Gmail mailbox — see Section 1.6)

- An appointment being confirmed by its assigned doctor — the patient is emailed the confirmed date, time, and doctor's name
- An appointment being rescheduled (date or time changed, including a missed appointment being rescheduled) or cancelled — the patient is emailed the change
- Appointment reminders — for confirmed appointments only, the patient is emailed twice: a day-before reminder (sent between 24 and 12 hours before the appointment) and a same-day reminder (sent between 2 hours and 30 minutes before). Each gives the date, time and doctor, asks the patient to arrive a few minutes early, and gives the front-desk phone number from Settings > Hospital Profile. A reminder is sent at most once, is skipped if the appointment was confirmed after its send time (the confirmation email already covered it), and is retried on the next check if sending fails, until its window closes. A background scheduler inside the backend checks every 5 minutes
- A lab result being marked completed — the patient is emailed that their result is ready, with the PDF report attached when one has been uploaded; editing a completed result re-sends the email with the corrected content

- An invoice reaching fully Paid — the patient is emailed their PDF receipt as an attachment. This applies to every invoice type identically (a regular consultation invoice, an appointment's auto-generated fee, or a lab order's auto-generated invoice), since all three are just rows in the same invoices table
- An invoice being cancelled — the patient is emailed that it is no longer due and that any payment already made will be refunded separately (the same email goes out when a prescription is cancelled)
- A refund being processed — the patient is emailed a refund confirmation
- If a patient has no email on file, the corresponding email is silently skipped — it never blocks or fails the underlying action (confirming the appointment, completing the result, recording the payment)

2.14 Error Page — route: * (404)

- Friendly "page not found" message with a link back to Dashboard

3. Backend Documentation (FastAPI + Uvicorn)

The backend is a FastAPI application served by Uvicorn, exposing a REST API under /api. Every endpoint below returns JSON and expects a valid JWT in the Authorization header unless it is an auth endpoint itself. The only route outside /api is GET /health.

3.1 Architecture Overview

- main.py — creates the FastAPI app, mounts routers, configures CORS and middleware, starts the reminder and expiry-alert scheduler, and serves GET /health
- routers/ — one router module per domain (auth, users, staff, patients, appointments, billing, pharmacy, laboratory, reports, dashboard, notifications, settings, refunds, search)
- models/ — SQLAlchemy async models mapping to database tables
- schemas/ — Pydantic request/response models for validation and OpenAPI docs
- services/ — business logic kept out of routers: stock_service.py (dispensing from the earliest-expiring batches, the pick lists and the hospital's own day), dosing_service.py (works out each prescription line's quantity and one-line instruction from the dose), prescription_view.py (builds a prescription for the viewing role and locks an unpaid one for the Pharmacist), invoice_service.py (server-side total calculation, invoice numbering, and the PDF receipt), notification_service.py (creating notifications for a role group or a specific user plus admins), email_service.py (every patient and staff email), reminder_service.py (finds confirmed appointments due a reminder and sends it), the drug expiry alert job (notifies Admin and Pharmacist as batches near expiry), file_storage_service.py (saves and reads lab result PDFs on the server's disk), and backup_service.py (builds the database backup zip: a pg_dump plus every uploaded document)
- dependencies.py — shared dependencies: get_current_active_user, require_role(...) guards, DB session
- core/constants.py — the fixed role lists behind lab-result visibility, the patient-profile sub-resources, appointment booking-note and appointment-result visibility and refund bank details, alongside the default module permissions
- core/security.py — Argon2 password hashing and JWT create/verify (access, refresh, and separate short-lived "action" tokens for set-password / reset-password links), all in one place so nothing else in the app calls the hashing or JWT libraries directly
- FastAPI auto-generates interactive API docs at /docs (Swagger) and /redoc

Deployment note: the system runs against a single PostgreSQL database, migrated with Alembic.

3.2 Database Schema

users (staff)

Field	Type	Notes
id	UUID, PK	
full_name	varchar	
email	varchar, unique	Used for login
password_hash	varchar, nullable	Argon2 hash. Nullable — an account has no usable password until the staff member sets their own via the emailed activation link
role	enum	admin, doctor, nurse, receptionist, pharmacist, lab_technician, accountant
department	varchar	Nullable
phone	varchar	

Field	Type	Notes
status	enum	active, inactive. An inactive account cannot log in, refresh a session, use a reset or activation link, or be assigned as an appointment or lab-order doctor
deactivated_at	timestamp with time zone, nullable	When the account was last deactivated; cleared on reactivation
deactivation_reason	varchar(300), nullable	The Admin's optional reason for the latest deactivation; cleared on reactivation
is_verified	boolean	False until the account is activated
email_notifications / low_stock_alerts / expiry_alerts / appointment_reminders	boolean	Per-user preference flags. low_stock_alerts and expiry_alerts are the ones the application uses: when one is false the user receives no low-stock or expiry notifications. The other two columns are stored on the table but have no setting in the interface
created_at / updated_at	timestamp	

patients

Field	Type	Notes
id	UUID, PK	
full_name / date_of_birth / gender	varchar / date / enum	
phone / email / address	varchar	
emergency_contact_name / relationship / phone	varchar	
blood_group / allergies	varchar / text	Nullable
insurance_provider / policy_no	varchar	Nullable
bank_name / bank_account_number	varchar	Nullable. Refund bank details, kept by the Accountant. Not part of patient create/update/read responses — read and written only through /api/patients/{id}/bank-details (Section 3.3)
created_at / updated_at	timestamp	

appointments

Field	Type	Notes
id	UUID, PK	
patient_id	FK → patients.id	
doctor_id	FK → users.id	
scheduled_at	timestamp (UTC)	
type	enum	consultation, follow_up, emergency
reason	text	
status	enum	pending, confirmed, completed, cancelled, no_show — see the state machine in Section 2.5

Field	Type	Notes
notes	text	Nullable. The Receptionist's booking note, entered when the appointment is booked. Returned only to Admin, Doctor, Nurse and Receptionist; every other role receives null
cancellation_reason	text	Nullable. Required when an appointment is cancelled. Returned only to Admin, Doctor, Nurse and Receptionist
invoice_id	FK → invoices.id	Nullable. The invoice generated when the appointment was booked; the assigned doctor can confirm only once it is paid in full. A rescheduled appointment shares the invoice of the appointment it replaces
rescheduled_to_id	FK → appointments.id	Nullable. Set on a no-show that has been rescheduled, pointing at the new appointment
confirmed_at	timestamp	Nullable. When the doctor confirmed the appointment
reminder_24h_sent_at / reminder_2h_sent_at	timestamp	Nullable. When each reminder email was sent; used so that a reminder is sent at most once
created_at / updated_at	timestamp	

appointment_results

Field	Type	Notes
id	UUID, PK	
appointment_id	FK → appointments.id, unique	One result per appointment. Written in the same step that completes the appointment and never edited. Returned only to Admin, Doctor, Nurse and Pharmacist; every other role receives it empty
diagnosis	text	Required. Up to 2,000 characters
consultation_note	text	Required. Up to 5,000 characters
created_at / updated_at	timestamp	created_at is when the appointment was completed

invoices, invoice_items & payments

Field	Type	Notes
invoices.id	UUID, PK	
invoices.patient_id	FK → patients.id	
invoices.status	enum	unpaid, partial, paid, cancelled, refunded — recomputed server-side after every payment; cancelled and refunded are terminal states set by the Cancel and Refund actions respectively, not by the normal payment-recompute path
invoices.discount / tax / total_amount	decimal	total_amount is always computed server-side, never trusted from the frontend
invoices.issued_at	timestamp	
invoice_items.invoice_id	FK → invoices.id	

Field	Type	Notes
invoice_items.description / qty / unit_price	varchar / int / decimal	Manually entered (e.g. a custom procedure), or auto-generated — "Consultation Fee" / "Follow Up Fee" / "Emergency Fee" from booking an appointment, or "Lab Test: <name>" from placing a lab order, or a drug's full name from a prescription
invoice_items.drug_id	FK → drugs.id, nullable	Set only when this line item came from a prescription (one line per drug); null for a manual or appointment/lab-generated line. Used by the refund workflow (Section 3.3) to compute a refund from returned drug items
payments.invoice_id	FK → invoices.id	
payments.amount / method / reference / paid_at	decimal / enum / varchar / timestamp	method: cash, card, insurance, transfer

refunds

Field	Type	Notes
id	UUID, PK	
invoice_id	FK → invoices.id	The invoice this refund was issued against
amount	decimal	Always computed server-side. If items were returned, this is the sum of returned quantity × unit price; if not, it is the amount entered directly, capped at the amount actually paid
reason	varchar, nullable	Free text. For a refund computed from returned items, it begins with which items and quantities were returned, followed by any reason text the staff member typed
processed_by	FK → users.id	The Accountant account that processed the refund
refunded_at	timestamp	
created_at / updated_at	timestamp	

One refund per invoice; refunding is terminal — a refunded invoice cannot be refunded again. A refund also flips the parent invoice's status to refunded and excludes it from Reports > Revenue from that point on (see Sections 2.10 and 4).

drugs, batches & prescriptions

Field	Type	Notes
drugs.id	UUID, PK	
drugs.name / category / manufacturer	varchar	The name is entered without the strength. All three are required
drugs.form	varchar	tablet, capsule, suppository, syrup, oral_drops, eye_drops, ear_drops, nasal_drops, injection, infusion (an IV drip bag), syringe, cream or other. Decides which of the fields below apply
drugs.strength_value / strength_unit	decimal / varchar	Nullable. The unit is mcg, mg, g, units or percent and must suit the form (Section 2.7). Syringes have no strength; for a drop, drip, cream or other item the Pharmacist may confirm there is none
drugs.strength_volume_ml	decimal, nullable	The volume the strength refers to (125 mg per 5 mL). Always stored in mL; empty when the unit is percent

Field	Type	Notes
drugs.volume_ml	decimal, nullable	Bottle, bag, vial or syringe size, always in mL (the form lets the Pharmacist type cL, which is converted)
drugs.routes	list, nullable	iv, im, subcut for an injection; rectal or vaginal for a suppository; iv for an IV drip
drugs.multi_dose / insulin_scale	boolean / int, nullable	A multi-dose vial (insulin) needs its volume and its strength per mL. An insulin syringe is scale 40 or 100
drugs.pack_type / units_per_pack	varchar / int	card, strip, box, bottle, vial, ampoule, bag, tube or pack. units_per_pack is more than 1 only for tablets, capsules, suppositories and syringes
drugs.unit_price / reorder_threshold	decimal / int	Both are per unit; the reorder level is typed in packs and stored as units. A low-stock notification fires the moment usable stock transitions to at or below reorder_threshold
drugs.discontinued_at / discontinued_reason	timestamp with time zone / varchar, nullable	Set when the drug is discontinued and cleared when it is reactivated. Nothing in the app deletes a drug
drugs (calculated)	—	stock_qty, expired_qty and next_expiry_date are not columns: they are calculated from the batches. stock_qty counts only units whose expiry date has not been reached
drugs unique index	—	Name, manufacturer, form, strength, strength volume, bottle size and insulin scale (capitals and extra spaces ignored) together are unique, so two drugs cannot be the same product
drug_batches.id / drug_id	UUID, PK / FK → drugs.id	Each delivery is its own batch
drug_batches.expiry_date	date	Must be after today (the hospital's day) when the batch is received
drug_batches.qty_received / qty_remaining	int	In units. qty_remaining falls as units are dispensed or written off
drug_batches.received_by	FK → users.id	The Pharmacist who recorded the delivery. The expiry alert already sent for the batch (90 days, 30 days, expired) is also recorded on it, so each is sent once
stock_write_offs	drug_id / batch_id / qty / reason / written_off_by	Who removed expired units from stock, from which batch, how many and why
dispense_allocations	—	Records, for each dispensed item, which batches its units were taken from and how many
prescriptions.id / patient_id / doctor_id	UUID / FK / FK	doctor_id is always the signed-in Doctor
prescriptions.invoice_id	FK → invoices.id, nullable	The invoice created when the prescription was saved (one line per drug)
prescriptions.status	enum	pending, dispensed, cancelled
prescriptions.prescribed_at / dispensed_at	timestamp with time zone	prescribed_at is the real time the prescription was saved
prescriptions.dispensed_by	FK → users.id, nullable	The Pharmacist who handed the drugs over. Empty when no dispenser is recorded

Field	Type	Notes
prescriptions.cancelled_at / cancellation_reason / cancelled_by	timestamp with time zone / varchar(300) / FK → users.id	Set when a pending prescription is cancelled. The reason is shown on the prescription and is never put in a notification
prescription_items.prescription_id / drug_id / qty	FK / FK / int	qty is in the drug's own unit and is always worked out or checked by the server
prescription_items.dose_value / route / frequency	decimal / varchar / varchar	What the doctor wrote. Empty when no dose was recorded
prescription_items.prn_doses / duration_value / duration_unit / total_doses	int / int / varchar / int	prn_doses is the number of doses supplied for a when-necessary frequency; duration_unit is hours, days, weeks or months
prescription_items.instructions / give_at	varchar(300) / varchar	Written instructions (for drops, creams and other items). give_at is home (taken away) or hospital (given before the patient leaves)

lab_tests, lab_orders & lab_results

Field	Type	Notes
lab_tests.id	UUID, PK	
lab_tests.name / category / price / turnaround_time	varchar / varchar / decimal / varchar	
lab_orders.id	UUID, PK	
lab_orders.patient_id / test_id / ordered_by	FK / FK / FK	ordered_by → users.id, must be an active user with the Doctor role
lab_orders.status	enum	pending, in_progress, completed
lab_orders.invoice_id	FK → invoices.id, nullable	Links each order to its auto-generated invoice; the payment gate on confirming an order checks this invoice's status
lab_results.order_id	FK → lab_orders.id, unique	
lab_results.result_data / notes / report_file_url	text / text / varchar	result_data is free-text, a plain string rather than structured data. report_file_url holds the stored path of the optional PDF report a lab technician attaches to a result; the file lives on the server's disk and is only served through the role-checked report endpoint
lab_results.completed_at	timestamp	Set when the order is marked completed. The Lab report's Avg. Turnaround is measured from the order's creation to this time

notifications

Field	Type	Notes
id	UUID, PK	
user_id	FK → users.id	Recipient — one row per recipient, even when the same event notifies several people
type	enum	low_stock, lab_result, appointment_reminder, general

Field	Type	Notes
message_key / message_params	varchar / json	A template key plus its variable data, resolved into a final sentence on the frontend at render time
is_read	boolean	Default false
created_at	timestamp	

app_settings

A single generic key/value table backs three otherwise-unrelated settings screens, rather than one dedicated table per screen — a deliberate space-saving choice given how small and simple each setting is.

Field	Type	Notes
id	UUID, PK	
key	varchar, unique	"hospital_profile", "role_permissions", or "appointment_fees" — one row per key
value	json	The actual setting data, shaped differently per key (e.g. the fee amounts, or the role-to-module permission map)

3.3 API Endpoints

Auth — /api/auth

Method	Endpoint	Description	Auth Role
POST	/api/auth/login	Authenticate, returns access + refresh JWT. A deactivated account gets HTTP 403	Public (rate-limited)
POST	/api/auth/refresh	Exchange the refresh token (sent in the request body) for a new access and refresh token. A deactivated account gets HTTP 403	Public (refresh-token verified)
POST	/api/auth/logout	Confirm sign-out. The session itself ends on the client by discarding both tokens; the server keeps no token list	All staff
GET	/api/auth/me	Return the current logged-in user's profile	All staff
POST	/api/auth/forgot-password	Send a password reset link/token by email. The reply is the same whether or not the address is registered, and no link is sent to a deactivated account	Public (rate-limited)
POST	/api/auth/reset-password	Set a new password using a reset token. A deactivated account is refused (HTTP 403)	Public
POST	/api/auth/set-password	Set the first password on a newly created account. A deactivated account is refused (HTTP 403)	Public (token-verified)
POST	/api/auth/change-password	Change the current user's own password (requires the current password)	All staff

Users — /api/users

Method	Endpoint	Description	Auth Role
PUT	/api/users/me	Update the current user's own profile info	All staff

Staff — /api/staff

Method	Endpoint	Description	Auth Role
GET	/api/staff	List active staff, filterable by role/department and searchable by name (?search=). Only an Admin passing ?status=inactive receives deactivated staff, newest deactivation first; only an Admin receives deactivated_at and deactivation_reason	All staff
POST	/api/staff	Create a new staff member (no password — activation link only)	Admin
GET	/api/staff/{id}	Get one staff member's details	All staff
PUT	/api/staff/{id}	Update a staff member's details. The last active Admin, and a Doctor with pending or confirmed appointments, cannot be given another role (HTTP 400)	Admin
PATCH	/api/staff/{id}/status	Deactivate (body: status inactive, optional reason up to 300 characters) or reactivate (status active) a staff account. Nothing is deleted. Refused with HTTP 400 for the caller's own account, for the last active Admin, and for a Doctor with any pending or confirmed appointment — the response then lists up to ten as blocking_appointments, with blocking_total	Admin

Patients — /api/patients

Method	Endpoint	Description	Auth Role
GET	/api/patients	List / search patients, paginated. Each row carries last_visit_at: the latest of the patient's registration, a completed appointment, a payment recorded on any of the patient's invoices and a dispensed prescription	All staff
POST	/api/patients	Register a new patient	Admin, Receptionist
GET	/api/patients/{id}	Get one patient's record (blood group and allergies are returned empty to the Accountant; bank details are never included)	All staff
PUT	/api/patients/{id}	Update patient details	Admin, Receptionist
GET	/api/patients/{id}/appointments	Get this patient's appointments. The booking note and the cancellation reason are returned only to Admin, Doctor, Nurse and Receptionist, and each appointment carries the doctor's result (empty until there is one) only for Admin, Doctor, Nurse and Pharmacist	Admin, Doctor, Nurse, Receptionist, Pharmacist
GET	/api/patients/{id}/invoices	Get this patient's invoices	Admin, Accountant

Method	Endpoint	Description	Auth Role
GET	/api/patients/{id}/lab-results	Get this patient's lab results; result_data, notes and the report link are returned empty for the Receptionist	Admin, Doctor, Nurse, Receptionist, Pharmacist, Lab Technician
GET	/api/patients/{id}/prescriptions	Get this patient's prescriptions, each with who dispensed it and when	Admin, Doctor, Nurse, Pharmacist
GET	/api/patients/{id}/bank-details	Get the patient's refund bank details	Admin, Accountant
PUT	/api/patients/{id}/bank-details	Replace the patient's refund bank details (a blank value clears it)	Accountant

Appointments — /api/appointments

Method	Endpoint	Description	Auth Role
GET	/api/appointments	List appointments — filterable by status, doctor_id, a from/to calendar-date range (used by the month Calendar view) and ?search= (patient name or patient code); paged with skip and limit, most recently changed first. The booking note and the cancellation reason are returned only to Admin, Doctor, Nurse and Receptionist; the list never carries the doctor's result	Admin, Doctor, Nurse, Receptionist
POST	/api/appointments	Book a new appointment (a time in the past is rejected; a 15-minute allowance covers walk-ins); also auto-generates a one-line invoice priced from the Admin-configured fee for that appointment type. The doctor must be an active Doctor	Admin, Receptionist
GET	/api/appointments/{id}	Get one appointment's details, including the status of its invoice (no amounts) and, for a rescheduled no-show, the appointment it was rescheduled to. The booking note and the cancellation reason are returned only to Admin, Doctor, Nurse and Receptionist, and the doctor's result (empty until there is one) only to Admin, Doctor and Nurse	Admin, Doctor, Nurse, Receptionist
PUT	/api/appointments/{id}	Edit an appointment — only while it is pending (once it is confirmed, completed, cancelled or no-show it is locked and the request is rejected with HTTP 400). Admin and Receptionist may edit any pending appointment; a Doctor only one they are personally assigned to. Changing the type re-prices the linked invoice while nothing has been paid on it. If the date/time changes the patient is emailed; moving it to a time in the past is rejected. A new doctor must be an active Doctor	Admin, Receptionist, or the assigned Doctor

Method	Endpoint	Description	Auth Role
PATCH	/api/appointments/{id}/status	Enforced state-machine transition. Confirm: only the specific doctor assigned to that appointment, and only once the invoice is paid in full (HTTP 400 otherwise). Complete: the assigned doctor, not before the scheduled time, with a result ({ diagnosis, consultation_note }, both required: HTTP 400 without it, and HTTP 400 if a result is sent with any other status); the result is saved in the same step and is never edited. No-show: Admin, Receptionist or the assigned Doctor, not before the scheduled time. Cancel (from pending, confirmed or no-show): Admin, Receptionist or the assigned Doctor, with a required reason — cancels the linked invoice and emails the patient. A rescheduled no-show can no longer be changed	See description
POST	/api/appointments/{id}/reschedule	Reschedule a no-show: creates a new pending appointment (same patient, doctor, type, reason and invoice) at the new date and time and links the no-show to it. No new billing; the patient is emailed. The new time must be in the future. Refused if the appointment's doctor has since been deactivated	Admin, Receptionist, or the assigned Doctor

Billing — /api/invoices

Every endpoint in this router — including plain reads — requires Admin or Accountant. The reads (list, detail, payments list, receipt) are open to both; every write (create, edit, cancel, record payment, refund) is Accountant-only, so an Admin calling one directly receives HTTP 403. No other role has any access to billing data.

Method	Endpoint	Description	Auth Role
GET	/api/invoices	List invoices — filterable by status and searchable with ?search= (patient name, patient code or invoice number), paged with skip and limit, newest first. Each row includes the patient code	Admin, Accountant
POST	/api/invoices	Create a new invoice with line items	Accountant
GET	/api/invoices/{id}	Get one invoice's full breakdown (for an appointment's invoice, also the reason a refund is not yet possible when the appointment has not been cancelled)	Admin, Accountant
PUT	/api/invoices/{id}	Edit invoice line items — only while the invoice is unpaid (HTTP 400 otherwise)	Accountant

Method	Endpoint	Description	Auth Role
PATCH	/api/invoices/{id}/cancel	Cancel an invoice nobody has fully paid — only unpaid or partial invoices qualify; a paid invoice must be refunded instead. Sets status to cancelled (terminal), excludes it from Reports > Revenue, and emails the patient. A paid, already cancelled or already refunded invoice is rejected (HTTP 400) with a message that names its state. The patient's email says any payment already made will be refunded separately. If the invoice belongs to a pending prescription, the prescription is cancelled too, and Nurses, Pharmacists and the prescribing doctor are notified	Accountant
POST	/api/invoices/{id}/payments	Record a payment against an invoice; recalculates status. Rejected on an invoice that is already paid, cancelled or refunded	Accountant
GET	/api/invoices/{id}/payments	List payments made on an invoice	Admin, Accountant
POST	/api/invoices/{id}/refund	Refund a paid invoice. Two modes: pass items (returned drug line items) to compute the amount automatically, or pass amount directly, up to the amount paid (the interface sends a plain amount). One refund per invoice; sets status to refunded. An appointment's invoice can be refunded only after the appointment has been cancelled (HTTP 400 otherwise). A prescription's invoice can be refunded only after the prescription has been cancelled, and never once it has been dispensed	Accountant
GET	/api/invoices/{id}/receipt	Generate and download a PDF receipt	Admin, Accountant

Pharmacy — /api/drugs, /api/prescriptions

Method	Endpoint	Description	Auth Role
GET	/api/drugs	List drugs, active ones by default. Filter by category, form and ?search= (name or manufacturer); paged with skip and limit, returning data and total. discontinued_only=true lists only discontinued drugs (Admin and Pharmacist; every other role always gets the active list). Each drug carries its display name, usable stock_qty, expired_qty and next_expiry_date	All staff
POST	/api/drugs	Add a new drug together with its first delivery (packs received and an expiry date after today). The fields required depend on the form and the strength unit must suit it (HTTP 400 otherwise); a drug with the same name, manufacturer, form and strength already in the catalogue is refused (HTTP 409)	Pharmacist

Method	Endpoint	Description	Auth Role
GET	/api/drugs/low-stock	List active drugs whose usable stock is at or below the reorder level	All staff
GET	/api/drugs/check-duplicate	Live check for the Add / Edit Drug form: same_name lists drugs that already use the name, and exact is set when the whole product (name, manufacturer, form, strength) already exists. exclude_id keeps an edited drug from matching itself	Admin, Pharmacist
GET	/api/drugs/{id}	Get one drug's details	All staff
PUT	/api/drugs/{id}	Update a drug's details and reorder level. Stock never changes here; the form and pack size cannot change while the drug has any units on hand (HTTP 400); a duplicate is refused (HTTP 409)	Admin, Pharmacist
GET	/api/drugs/{id}/batches	List the drug's batches: expiry date, units received and remaining, and status (usable, expired or empty)	Admin, Pharmacist
POST	/api/drugs/{id}/restock	Add a delivery as a new batch (packs and an expiry date after today). Refused for a discontinued drug	Pharmacist
POST	/api/drugs/batches/{batch_id}/write-off	Remove the units left in an expired batch from stock and record who did it. A batch that has not expired, or is empty, is refused (HTTP 400)	Pharmacist
POST	/api/drugs/{id}/discontinue	Phase a drug out without deleting it (optional reason). Refused while the drug has usable stock or a pending prescription includes it; expired units still on the shelf are written off in the same step	Admin, Pharmacist
POST	/api/drugs/{id}/reactivate	Bring a discontinued drug back	Admin, Pharmacist
GET	/api/prescriptions	List prescriptions, newest first, filterable by status and searchable with ?search= (patient name or patient code); paged with skip and limit. A Doctor sees only their own. A pending prescription whose invoice is not fully paid is returned to a Pharmacist as a locked row with no contents	Admin, Doctor, Nurse, Pharmacist
POST	/api/prescriptions/preview	Work out each line's quantity, price and any problem with the same code that saves, so the form can show the total as the doctor types. Nothing is stored	Doctor
POST	/api/prescriptions	Create a prescription. The server works out every quantity, refuses a drug that is unknown, discontinued, repeated or short of usable stock, creates the invoice (one line per drug) and notifies Admin and Pharmacist. A saved prescription cannot be edited	Doctor

Method	Endpoint	Description	Auth Role
GET	/api/prescriptions/{id}	Get one prescription: instructions, quantities, payment status (never amounts), who dispensed it and any cancellation. A Pharmacist opening a pending, unpaid prescription receives HTTP 403. Only Pharmacist and Admin also receive which batch to take each drug from	Admin, Doctor, Nurse, Pharmacist
PATCH	/api/prescriptions/{id}/cancel	Cancel a prescription that has not been dispensed; a written reason is required. Voids the invoice and emails the patient. Only the prescribing Doctor or an Admin. Notifies Nurses, Pharmacists and the Accountant (with a refund prompt if payment was made), and the prescribing doctor when an Admin cancels. Notifications never carry the reason	Admin, prescribing Doctor
PATCH	/api/prescriptions/{id}/dispense	Dispense medication. The body must be {"confirmed": true} (HTTP 400 without it) and the invoice must be paid in full (HTTP 400 otherwise). Every item is checked before any stock is taken, stock leaves the earliest-expiring batches first, the Pharmacist is recorded as dispensed_by, and a low-stock notification fires if a drug newly crosses its reorder level	Pharmacist

Laboratory — /api/lab-tests, /api/lab-orders

Method	Endpoint	Description	Auth Role
GET	/api/lab-tests	List the test catalog	All staff
POST	/api/lab-tests	Add a new test type to the catalog	Lab Technician
PUT	/api/lab-tests/{id}	Edit a test's name, category, price, or turnaround time	Lab Technician
GET	/api/lab-orders	List lab orders, filterable by status; result_data, notes and the report link are empty for the Receptionist	Admin, Doctor, Nurse, Receptionist, Pharmacist, Lab Technician
POST	/api/lab-orders	Order a lab test for a patient; auto-generates a linked invoice priced from the catalog, and fires a notification to Admin + Lab Technician. The ordering doctor (ordered_by) must be an active Doctor	Admin, Doctor, Nurse, Receptionist, Pharmacist, Lab Technician (not the Accountant)
GET	/api/lab-orders/{id}	Get one lab order's details, including its linked invoice's payment status; result_data, notes and the report link are empty for the Receptionist	Admin, Doctor, Nurse, Receptionist, Pharmacist, Lab Technician

Method	Endpoint	Description	Auth Role
PUT	/api/lab-orders/{id}/result	Submit result data / notes for an order, optionally with a PDF report. A completed result can be edited afterward (re-sends the patient's result-ready email)	Lab Technician
GET	/api/lab-orders/{id}/report	Download the PDF report attached to a result, through a role-checked endpoint (files are never served by a public URL)	Admin, Doctor, Nurse, Pharmacist, Lab Technician
PATCH	/api/lab-orders/{id}/status	Update status. pending → in_progress is blocked (HTTP 400) unless the linked invoice is fully paid. completed fires a notification to the ordering doctor + all Admins	Lab Technician, Admin

Reports — /api/reports

Method	Endpoint	Description	Auth Role
GET	/api/reports/revenue	Revenue totals over a range (?range=weekly, monthly or yearly). Counts invoices at the moment they're issued, not when paid; cancelled and refunded invoices are excluded. Outstanding is the unpaid balance (totals minus payments received) on unpaid and partly paid invoices	Admin, Accountant
GET	/api/reports/appointments	Appointment volume & status breakdown (?range=weekly, monthly or yearly)	Admin
GET	/api/reports/patients	New patient registrations over time, plus the total number of patients (?range=weekly, monthly or yearly)	Admin
GET	/api/reports/pharmacy	Stock levels (usable, unexpired stock only) & dispensing trends (?range=weekly, monthly or yearly)	Admin
GET	/api/reports/lab	Lab test volume, completions and average turnaround in hours (?range=weekly, monthly or yearly)	Admin
GET	/api/reports/export	Export reports as PDF or Excel. Query: type (revenue, patients, appointments, pharmacy, lab, or all — default all), format (pdf or excel), range (weekly, monthly or yearly). type=all returns one file with every report under its own header — one page per report in the PDF, one sheet per report in the Excel file. An Accountant can export Revenue only: any other type returns HTTP 403, and all resolves to revenue	Admin, Accountant

Dashboard — /api/dashboard

Method	Endpoint	Description	Auth Role
GET	/api/dashboard/stats	Stat-card numbers, only the cards the caller's role may see: total patients (all staff), today's appointments (Admin, Doctor, Nurse, Receptionist), pending bills (Admin, Accountant), low-stock drugs (Admin, Pharmacist), pending lab results (Admin, Lab Technician)	All staff (each sees its own cards)
GET	/api/dashboard/recent-patients	Last few registered patients	Admin, Doctor, Nurse, Receptionist
GET	/api/dashboard/today-appointments	The hospital's own day, in time order; a Doctor sees only their own appointments	Admin, Doctor, Nurse, Receptionist

Notifications — /api/notifications

Method	Endpoint	Description	Auth Role
GET	/api/notifications	List notifications for the current user	All staff
PATCH	/api/notifications/{id}/read	Mark one notification as read	All staff
PATCH	/api/notifications/read-all	Mark all notifications as read	All staff

Refunds — /api/refunds

Audit view of every refund already processed via POST /api/invoices/{id}/refund above. Listing is open to Admin and Accountant; exporting is Accountant-only. This router only lists and exports what has already happened — it is not where a refund is created (only the Accountant can create one), and it is intentionally excluded from the configurable Roles & Permissions matrix (Section 1.4), so it can never be granted to any role other than Admin and Accountant.

Method	Endpoint	Description	Auth Role
GET	/api/refunds	List refunds within a rolling date range (?range=weekly, monthly or yearly — last 7, 30 or 365 days; default weekly), paginated with skip and limit. Returns data (invoice #, patient, amount, reason, who processed it, and an inferred source: Appointment / Lab Order / Prescription / Manual Invoice), total, and total_amount (a server-side sum over the whole range)	Admin, Accountant
GET	/api/refunds/export	Export the full refund history as an Excel (.xlsx) file	Accountant

Settings — /api/settings

Method	Endpoint	Description	Auth Role
GET	/api/settings/hospital-profile	Get hospital name, address, contact details	All staff
PUT	/api/settings/hospital-profile	Update hospital profile	Admin
GET	/api/settings/preferences	Get the current user's own preferences, plus the list of those that apply to their role (Low Stock Alerts and Expiry Alerts for Admin and Pharmacist; none for every other role)	All staff

Method	Endpoint	Description	Auth Role
PUT	/api/settings/preferences	Update the current user's own preferences; a flag that does not apply to the caller's role is ignored	All staff
GET	/api/settings/role-permissions	Get the module-permissions map — read access is open to every role, since every user's own sidebar is built from this on login	All staff
PUT	/api/settings/role-permissions	Change which modules each role can access	Admin
GET	/api/settings/appointment-fees	Get the fixed Consultation / Follow-up / Emergency fees	Admin
PUT	/api/settings/appointment-fees	Change the fixed fees used to auto-invoice new appointments	Admin
GET	/api/settings/backup	Download a .zip containing a real pg_dump of the database (database.sql), every uploaded document (files/), and a README.txt with restore steps. There is no in-app restore	Admin

Search — /api/search

Method	Endpoint	Description	Auth Role
GET	/api/search	Navbar search: ?q= (2 or more characters) returns up to 5 matching patients, appointments and invoices, only the groups the caller's role may see (patients: all staff; appointments: Admin, Doctor, Nurse, Receptionist; invoices: Admin, Accountant). Never returns notes, cancellation reasons or amounts. Rate-limited to 60 requests per minute	All staff (groups vary by role)

System — /health

Method	Endpoint	Description	Auth Role
GET	/health	Health check, served at the server root (not under /api). Returns the status, the app name and the version	Public

4. Known Limitations

4.1 Scope of This Documentation

This document describes MEDCORE HMS as it is built and delivered. Every module, screen, workflow, role permission, database table and API endpoint the system has is described in Sections 1 to 3, so those sections together form the full inventory of what the application does.

> **Rule of thumb:** A feature, screen, workflow or integration should be treated as not included unless this documentation describes it. Where this section says something is not included, it is not part of this build, and it is not partially implemented.

MEDCORE HMS is built for an outpatient hospital or clinic. Every hospital works differently, so the source code is written to be adapted. Anything listed in Section 4.2 can be added, and existing behaviour can be changed, as a customization for a specific hospital (see Section 4.4). If a feature you need is not described in this document, please ask before assuming it exists.

4.2 Not Included in This Build

The following are not part of the current build.

Clinical care

- Vital signs (temperature, pulse, respiration, blood pressure) and nursing observations
- Medical history and family history records
- Clinical record-keeping for the Nurse role (the Nurse role can view records and create lab orders)

Inpatient services

- Admissions, wards and beds, transfers and discharge summaries
- Operating theatre scheduling

Diagnostics

- Radiology and imaging orders, or image storage
- Connection to laboratory analysers or other medical devices

Patients and communication

- A patient portal or patient mobile app
- SMS or WhatsApp notifications (notifications are shown in the app, and sent by email to patients and staff)

Billing and insurance

- Insurance claim submission and tracking (insurance details are recorded on the patient, but claims are not processed)
- Online payment gateways (payments are recorded by the Accountant)

Organisation

- More than one hospital or branch in a single installation
- Languages other than English

4.3 How the System Is Designed to Run

- **Local network.** The system runs on a server inside the hospital and is reached over the hospital's own network. It is not designed to be hosted publicly on the internet.

- **Email.** Emails are sent from the hospital's own Gmail account. A Google Workspace (business) account on the hospital's own domain is recommended for real use, because a personal account sending many automated messages is more likely to be treated as spam.
- **Backups and restore.** An Admin downloads a complete backup (the database, the uploaded lab result PDFs and restore instructions, in one file) from Settings > Backup & Data. Backups are taken when requested; the application does not schedule them. Restoring follows the instructions inside the backup file. There is no restore button, by design, because a restore replaces all live data. The Install, Backup and Restore Guide supplied with the project describes the full procedure.
- **Rate limits.** Login and search limits are counted in the server's memory by default and reset when the backend restarts. Redis can be used to keep the counts across restarts.
- **Times.** Appointment times are stored in UTC. Screens show them in the viewing browser's time zone, and patient emails show them in the hospital's configured time zone.

4.4 Changes and Additional Features

Features that are not included, and changes to how existing features work, can be provided as a customization for a particular hospital. To discuss a change, contact the developer with a description of the workflow you need.

A written scope and quotation is provided before any work starts, and customizations are delivered with updated documentation.

Developed by Mgboji Chinonso Joshua (BOHANOS)